

DCST1005 – Digital infrastruktur og cybersikkerhet

Mock Eksamen 2

Tid: 3 timer

Hjelpemidler: Ingen

Totalt antall poeng: 100

Denne øvingseksamen er utformet for å gi deg trening i eksamensformat og pensum. MERK! Det kan være noen spørsmål som er litt på siden av pensum/hva vi har vært igjennom i praktiske øvinger i faget. Formålet er både å trene på eksamensformat og flette inn pensum.

Del A – Flervalg (12 spørsmål, 1 poeng hver = 12 poeng)

Velg ett svar per spørsmål.

1. Hva er «single sign-on» (SSO) i kontekst av Active Directory?
 - a) En funksjon som lar brukere logge inn på én maskin og automatisk få tilgang til alle nettverksressurser de har rettigheter til, uten å måtte autentisere seg på nytt
 - b) En sikkerhetspolicy som krever at brukere logger inn med to faktorer
 - c) En mekanisme for å synkronisere passord mellom flere domenekontrollere
 - d) En funksjon som sperrer kontoen etter ett mislykket innloggingsforsøk
2. Hva er formålet med en «Read-Only Domain Controller» (RODC)?
 - a) En domenekontroller som kun håndterer lesing av filer fra filserveren
 - b) En domenekontroller beregnet for filialer eller usikre lokasjoner, der full skrive-tilgang til AD-databasen ikke er ønskelig
 - c) En domenekontroller som kun kan administreres via Windows Admin Center
 - d) En domenekontroller uten DNS-funksjonalitet
3. Hva er «Resultant Set of Policy» (RSOP), og når er det nyttig?
 - a) Et verktøy for å se hvilke GPO-er som faktisk gjelder for en bestemt bruker eller maskin, nyttig ved feilsøking av Group Policy
 - b) En rapport over alle aktive brukerkontoer i et domene

- c) En funksjon som automatisk løser konflikter mellom motstridende GPO-er
 - d) En oversikt over hvilke OU-er som har arv deaktivert
-

4. Hva skjer med tillatelser på en fil når den kopieres fra én NTFS-mappe til en annen NTFS-mappe på samme volum?

- a) Filen beholder sine opprinnelige tillatelser
 - b) Filen arver tillatelsene fra destinasjonsmappen
 - c) Filen mister alle tillatelser og må konfigureres på nytt
 - d) Filen får en kombinasjon av kilde- og destinasjonstillatelser
-

5. Hva er forskjellen mellom «explicit» og «inherited» NTFS-tillatelser?

- a) Eksplisitte tillatelser er satt direkte på objektet, arvede tillatelser kommer fra en overordnet mappe
 - b) Arvede tillatelser har alltid høyere prioritet enn eksplisitte tillatelser
 - c) Eksplisitte tillatelser gjelder kun for filer, arvede tillatelser gjelder kun for mapper
 - d) Det er ingen praktisk forskjell mellom de to typene
-

6. En bruker klager på at hun kan lese filer i en delt mappe, men ikke opprette nye filer. Administratoren ser at brukeren har NTFS-tillatelsen «Read & Execute» på mappen. Hva er den mest sannsynlige årsaken til problemet?

- a) Brukeren mangler «Write»-tillatelse på NTFS-nivå
 - b) Nettverksdeling-tillatelsene overstyrer NTFS og gir kun lesetilgang
 - c) Group Policy blokkerer skriving til nettverksstasjoner
 - d) Brukeren er medlem av en gruppe som har «Deny Write» satt
-

7. Hva er «Azure Bastion», og hvilket sikkerhetsproblem løser det?

- a) En tjeneste for automatisk sikkerhetskopiering av virtuelle maskiner i Azure
 - b) En administrert tjeneste som gir sikker RDP/SSH-tilgang til virtuelle maskiner direkte via nettleseren, uten at maskinene trenger offentlig IP-adresse
 - c) En brannmurtjeneste som beskytter Azure-ressurser mot DDoS-angrep
 - d) Et verktøy for å skanne Azure-ressurser for sikkerhetssårbarheter
-

8. Hva er «egress-trafikk» i Azure-kontekst, og hvorfor er det relevant fra et kostnadsperspektiv?

- a) Trafikk som går inn i Azure fra internett – dette faktureres per gigabyte
- b) Trafikk som går ut av Azure til internett eller andre regioner – dette kan medføre utgående dataoverføringskostnader

- c) Trafikk mellom to virtuelle maskiner i samme subnett – dette er alltid gratis
 - d) Administrativ trafikk generert av Azure-plattformen selv
-

9. Hva er forskjellen mellom «Azure Firewall Standard» og «Azure Firewall Basic»?

- a) Basic støtter kun inngående trafikkregler, Standard støtter både inngående og utgående
 - b) Standard tilbyr avanserte funksjoner som trusselintelligens og IDPS, Basic er en forenklet versjon beregnet på mindre miljøer med lavere kostnad
 - c) Basic kan ikke brukes i en hub-spoke topologi
 - d) Standard er en eldre versjon som Microsoft planlegger å fase ut
-

10. Hva er «Infrastructure as Code» (IaC), og hvilket problem løser det sammenlignet med manuell ressursoppretting i Azure Portal?

- a) En metode for å automatisk skalere infrastruktur basert på belastning
 - b) En tilnærming der infrastruktur beskrives i kode (f.eks. ARM-maler eller Bicep), noe som gir reproducerbare, versjonskontrollerte og konsistente miljøer
 - c) Et Azure-verktøy som genererer dokumentasjon av eksisterende infrastruktur automatisk
 - d) En praksis der alle Azure-ressurser navngis etter en bestemt konvensjon
-

11. Hva er en «service principal» i Azure Entra ID?

- a) En administratorkonto med globale rettigheter i Azure-tenanten
 - b) En identitet som representerer en applikasjon eller et script, og som kan tildeles RBAC-roller for å gi programmatisk tilgang til Azure-ressurser
 - c) En type brukerkonto beregnet for servicemedarbeidere uten personlige kontoer
 - d) En automatisk opprettet konto som Azure bruker internt for ressursstyring
-

12. Hva er forskjellen mellom `Write-Host` og `Write-Output` i PowerShell?

- a) `Write-Host` skriver til skjermen og kan ikke fanges opp av pipeline, `Write-Output` sender objektet videre i pipeline og kan brukes i videre behandling
 - b) `Write-Output` skriver kun til loggfiler, `Write-Host` skriver til skjermen
 - c) Det er ingen funksjonell forskjell – begge gjør det samme
 - d) `Write-Host` er kun tilgjengelig i PowerShell 7, `Write-Output` fungerer i alle versjoner
-

Del B – Windows Server og on-premises administrasjon (30 poeng)

Kontekst: InfralT.sec skal gjennomføre en sikkerhetsgjennomgang av sitt on-premises miljø. Du er ansvarlig for å vurdere og forbedre AD-strukturen og GPO-konfigurasjonen.

Oppgave B1 – Active Directory og sikkerhet (15 poeng)

- a) En nyansatt IT-administrator skal overta driftsansvaret for domenet. Forklar prinsippet om minste privilegium i en AD-kontekst, og beskriv hvordan du ville tildelt nødvendige rettigheter uten å gjøre vedkommende til Domain Admin. Gi konkrete eksempler på hvilke rettigheter som kan delegeres og hvordan. (6 poeng)
- b) Selskapet ønsker å innføre krav om at alle domenebrukere må ha passord på minimum 12 tegn, med kompleksitetskrav, og at passordet må byttes hver 90. dag. Beskriv to ulike måter dette kan håndheves i Active Directory, og forklar fordelene med den ene fremfor den andre i et miljø med ulike krav per avdeling. (5 poeng)
- c) Forklar hva en «stale computer account» er i Active Directory, hvilken sikkerhetsrisiko det utgjør, og hva du ville gjort for å rydde opp. (4 poeng)
-

Oppgave B2 – Group Policy (15 poeng)

- a) IT-avdelingen ønsker å distribuere et bestemt program til alle maskiner i Salg-avdelingen via Group Policy. Beskriv hvordan Software Installation via GPO fungerer, hvilken type GPO-innstilling som brukes, og hvilke krav som stilles til hvordan programmet pakkes. (5 poeng)
- b) En administrator har opprettet en GPO som skal hindre brukere i å installere programvare. Etter å ha koblet GPO-en til riktig OU rapporterer brukerne at de fortsatt kan installere programmer. Beskriv en systematisk fremgangsmåte for å feilsøke dette, og nevnt minst tre mulige årsaker. (6 poeng)
- c) Forklar hva «WMI-filtre» på GPO-er er, og gi et eksempel på når det er nyttig å bruke et WMI-filter fremfor å opprette separate OU-er for å styre hvilke maskiner en GPO gjelder for. (4 poeng)
-

Del C – Azure og offentlig sky (30 poeng)

Kontekst: InfralT.sec vurderer å koble sitt on-premises miljø til Azure for å etablere en hybrid skyarkitektur.

Oppgave C1 – Hybrid sky og nettverksdesign (15 poeng)

- a) Forklar hva en Point-to-Site (P2S) VPN-tilkobling er, og beskriv et scenario der dette er en mer hensiktsmessig løsning enn en Site-to-Site (S2S) VPN. (5 poeng)

b) InfracT.sec ønsker å synkronisere filer mellom en on-premises filserver og Azure, slik at filer er tilgjengelige fra begge steder. Forklar hvilken Azure-tjeneste som passer til dette formålet, hvordan den fungerer på overordnet nivå, og nevnt én viktig begrensning du bør være klar over ved implementasjon. (5 poeng)

c) Forklar hva «private IP-adresse» kontra «offentlig IP-adresse» betyr for en virtuell maskin i Azure, og begrunn hvorfor det som hovedregel er god praksis å unngå å tildele offentlige IP-adresser direkte til virtuelle maskiner i et produksjonsmiljø. (5 poeng)

Oppgave C2 – Sikkerhet og tilgangsstyring (15 poeng)

a) Beskriv hva «Azure Defender for Cloud» (tidligere Security Center) er, og nevnt to konkrete eksempler på sikkerhetsproblemer det kan identifisere i et Azure-miljø. (5 poeng)

b) En virtuell maskin i Azure skal kunne lese hemmeligheter (secrets) fra Azure Key Vault uten at noen legitimasjon er lagret i koden eller på maskinen. Forklar hvilken mekanisme i Azure som muliggjør dette, og beskriv på overordnet nivå hvordan det settes opp. (6 poeng)

c) Forklar hva «network segmentation» betyr i en Azure-kontekst, og begrunn hvorfor det er viktig å segmentere et produksjonsmiljø fremfor å plassere alle ressurser i ett stort subnett. (4 poeng)

Del D – PowerShell og automatisering (26 poeng)

Kontekst: InfracT.sec ønsker å automatisere rapportering av gruppemedlemskap i Active Directory. Hver måned skal IT-avdelingen ha en oversikt over alle medlemmer i sikkerhetsgruppene GG-Økonomi , GG-Salg og GG-IT-drift .

En ferdig rapport skal lagres som en tekstfil (grupperrapport.txt) med følgende format:

```
=== GG-Økonomi ===
kariols
perhan
...

=== GG-Salg ===
oleand
...
```

Scriptet skal kjøres på DC1 og håndtere situasjoner der en gruppe ikke finnes eller er tom.

Oppgave D1 – Pseudokode (26 poeng)

a) Skriv et PowerShell-script i pseudokode som løser oppgaven beskrevet ovenfor. Scriptet skal være robust, håndtere feil på en kontrollert måte, og gi et sporbart resultat av hva som skjedde under kjøringen. *(18 poeng)*

b) Begrunn kort tre sentrale valg du tok i utformingen av scriptet, og forklar hvorfor disse valgene gjør scriptet bedre egnet for bruk i et produksjonsmiljø. *(8 poeng)*

— Lykke til! —